

# Contents

|                                                                                                                       |          |
|-----------------------------------------------------------------------------------------------------------------------|----------|
| <b>Requirements for authorization in UDM</b>                                                                          | <b>2</b> |
| What restrictions do we need? . . . . .                                                                               | 2        |
| <b>Integration of UDM Authoriztion into the Guardian concept</b>                                                      | <b>3</b> |
| Permissions . . . . .                                                                                                 | 3        |
| Differentiation of <b>search</b> vs <b>read</b> permissions . . . . .                                                 | 4        |
| Extended attributes . . . . .                                                                                         | 4        |
| Conditions provided by UDM . . . . .                                                                                  | 4        |
| Default example roles . . . . .                                                                                       | 5        |
| Wildcard permissions . . . . .                                                                                        | 5        |
| <b>Known problems with Guardian</b>                                                                                   | <b>5</b> |
| General/Conceptual problems . . . . .                                                                                 | 5        |
| Ambiguity of implementation . . . . .                                                                                 | 5        |
| Capabilities are bound to roles . . . . .                                                                             | 6        |
| Restricted charset . . . . .                                                                                          | 6        |
| Capability namespace binding restricted to the permission namespace . . . . .                                         | 7        |
| No dynamic contexts allowed . . . . .                                                                                 | 7        |
| No removal in Guardian possible . . . . .                                                                             | 8        |
| Permission granting: no negative permissions . . . . .                                                                | 8        |
| No language to describe rules, just HTTP API endpoints with JSON payloads . . . . .                                   | 9        |
| Security Impacts . . . . .                                                                                            | 11       |
| Availability of UDM . . . . .                                                                                         | 11       |
| Information disclosure . . . . .                                                                                      | 12       |
| OPA/Rego doesn't know LDAP DNs . . . . .                                                                              | 12       |
| Guardian as Policy Information endpoint doesn't add security to the whole system architecture automatically . . . . . | 12       |
| Guardian has no way to trace decisions . . . . .                                                                      | 13       |
| Guardian debugabilityw . . . . .                                                                                      | 13       |
| Guardian API design: new/old state of targets not required for filtering . . . . .                                    | 13       |
| Performance Impacts . . . . .                                                                                         | 13       |
| Search results must provide full data to Guardian . . . . .                                                           | 13       |
| Guardian API design: extensive data format . . . . .                                                                  | 13       |
| UDM is synchronous . . . . .                                                                                          | 13       |
| Rule evaluation stays on the client. . . . .                                                                          | 13       |
| check-permissions vs get-permissions endpoints . . . . .                                                              | 14       |
| UDM actions do a lot of sub-actions . . . . .                                                                         | 14       |
| Management UI Usability problems . . . . .                                                                            | 14       |
| Managment API bugs and issues . . . . .                                                                               | 14       |
| Changing conditions impossible . . . . .                                                                              | 14       |
| Failed decoding of input JSON data . . . . .                                                                          | 14       |
| Unreachable API . . . . .                                                                                             | 15       |
| Performance of Management API . . . . .                                                                               | 15       |
| cyclic dependency problem . . . . .                                                                                   | 15       |
| Questions . . . . .                                                                                                   | 15       |
| Conclusion . . . . .                                                                                                  | 16       |
| TODOs: describe the following . . . . .                                                                               | 16       |
| Comparision with LDAP ACLs . . . . .                                                                                  | 16       |

|                                                                           |           |
|---------------------------------------------------------------------------|-----------|
| <b>Implementation of Authorization in UDM</b>                             | <b>16</b> |
| How to initialize a service to enable the authorization engine? . . . . . | 17        |
| [TOC]                                                                     |           |

## Requirements for authorization in UDM

- No LDAP ACL's **strategic decision**
- Authorization for UDM objects types and properties, not LDAP attributes **strategic decision**
- Authorization based on
  - the role (**guardianRoles**) of the *actor*
  - the DN (**position**) of the *target*
- Probably a future need for “value-based” authorization (e.g. `username` can not be `root`, group memberships can not be `Domain Admins`, certain `guardianRoles` are allowed)
- Privileged LDAP connection for access to database after authorization (not user connection)
  - This introduces a security risk for UDM extensions. We can not technically enforce that Python code from 3rd parties do the authorization part.
    - \* **Product Management decision:** we can ignore this for now, it is the responsibility of the operator and/or the “manufacturer” to ensure that 3rd party extensions work correctly
    - \* Furthermore we want to provide the possibility to extend UDM in a declarative way (e.g. via `YAML`) to get rid of custom Python business logic
- Customers can create roles and assign permissions for those roles
- If possible, the Guardian should be used

Otherwise we don't have clear requirements about the current and future use cases: We currently only have vague statements to support three roles: `OU Admin`, `Computer Join Operator`, `Helpdesk Operator`.

But we have knowledge about the product: \* We know the security implications of certain attributes \* We know the requirements of the self service \* We know the current UCS LDAP ACL's \* We know the LDAP ACLs of `UCS@school`

And with this in mind (and considered), we know that the product should go into the direction that these same things can be realized with UDM permissions

### What restrictions do we need?

- no writing to `users/user:guardianRole`, `groups/group:guardianMemberRole`
- no reading of `users/user:password`, `users/user:serviceSpecificPassword` (but maybe write)
- sensitive rules about `users/user:` `overridePWLength`, `overridePWHistory`, `shell`, `unixhome`, `locked/unlock`, `disabled`, `gidNumber` `uidNumber`.
- restrict the possible values for `primaryGroup` and `groups` (don't allow to put into `Domain Admins`)
- ... to be continued ...

# Integration of UDM Authorization into the Guardian concept

Guardian is an Authorization Information Point, meaning it doesn't enforce any policies. UDM is the layer which enforces the rule evaluation.

## Permissions

UDM by default provides permissions:

- A namespace for each UDM module: `udm:{module}`:
- Capabilities for general actions of a all UDM modules (if the module supports the action):
  - Capability: `condition objectType == "users/user"` grants the permission `udm:{module}:create` allows to create objects of this module
  - Capability: `condition objectType == "users/user"` grants the permission `udm:{module}:modify` allows to modify objects of this module
  - Capability: `condition objectType == "users/user"` grants the permission `udm:{module}:rename` allows to rename objects of this module
  - Capability: `condition objectType == "users/user"` grants the permission `udm:{module}:remove` allows to remove objects of this module
  - Capability: `condition objectType == "users/user"` grants the permission `udm:{module}:move` allows to move objects of this module
  - Capability: `condition objectType == "users/user"` grants the permission `udm:{module}:search` allows to search objects of this module
  - Capability: `condition objectType == "users/user"` grants the permission `udm:{module}:read` allows to read a specific object of this module
  - Capability: `condition objectType == "users/user"` grants the permission `udm:{module}:reports-type-query` allows to query the available report types of this module
  - Capability: `condition objectType == "users/user"` grants the permission `udm:{module}:report-create` allows to create a report for objects of this module
- For every UDM property of all UDM modules:
  - Permission `udm:{module}:read-property-{property}` allows to read the property value
  - Permission `udm:{module}:search-property-{property}` allows to use the property in a search filter
  - Permission `udm:{module}:write-property-{property}` allows to write the property value in a `create` or `modify` action
  - Permission `udm:{module}:readonly-property-{property}` restricts the `write` permissions back to `read` permissions again
  - Permission `udm:{module}:writeonly-property-{property}` restricts the permission to `write` without having `read` or `search` permissions
  - Permission `udm:{module}:none-property-{property}` restricts the `write` or `read` permissions back to `none` permissions again
- Wildcard-Permissions:
  - For the realization of a simple Domain Administrator role, wildcard permissions exists. They MUST NOT be used otherwise.
  - `~~Permission: udm:{module}:*` allows any of the above UDM module actions~~ (overcomplicates Guardian handling)

- Each of the per-property permissions above allows to specify `*` as property name, which applies to all properties the module provides.
- This is security critical and then must be combined with further restrictions, for example:
  - \* `udm:{module}:write-property-*` +
  - \* `udm:{module}:readonly-property-guardianRoles` +
  - \* `udm:{module}:none-property-password` or `udm:{module}:writeonly-property-password`

## Differentiation of search vs read permissions

What would it help to differentiate a **search** permission, while we already have a general **read** permission to retrieve a specific single object?

1. UDM modules support a optional **search** operation. If no permissions for searching exists for the specific module, the search form is not rendered (but opening specific objects is possible e.g. via the LDAP directory tree). The same applies to the **report-create** permission, which makes the button in the UI (in)visible.
2. Another use case could be, that users should not get the permissions to open a certain object type, while the user object itself allows to choose objects of such objects in a selection list. Filling the selection list then requires the permission for the **search** operation.

## Extended attributes

After the installation of an extended attribute, or an app which provides UDM modules or properties, the rules have to be re-created in Guardian via: `/usr/share/univention-directory-manager-tools/"$@" create-permissions`

## Conditions provided by UDM

Permissions are granted by Capabilities, which can restrict the permissions by adding certain Conditions.

UDM provides the following conditions:

- `udm:conditions:target\_position\_in` with parameters `position=`, `scope=` which restricts the permissions to the given LDAP DN `position` using one of the LDAP scopes `one`, `base`, `sub`.
- `udm:conditions:target\_position\_from\_context` with parameters `context=`, `scope=` which restricts the permissions to the LDAP DN position read from the given context using one of the LDAP scopes `one`, `base`, `sub`.
- `udm:conditions:target\_property\_value\_compares` with parameters `property` `operator` `value`, where operator is one of: `==`, `!=`, `regex-match`, `regex-nomatch`, `==-i`, `!=-i`, `regex-match-i`, `regex-nomatch-i`
- `udm:conditions:target\_property\_value\_dn\_compares` with parameters `property` `operator` `value`, where operator is one of: `==`, `!=`, `==-i`, `!=-i`, `subtree`, `onelevel`, `subtree-i`, `onelevel-i`.
- `udm:conditions:objecttype\_equals` with parameters `objectType=` which restricts the action to any UDM modules name.
- `udm:conditions:property\_equals` with parameters `property=` which restricts the action to any UDM modules property name. Must be used with the AND operator and the previous condition.

- (`udm:conditions:action\_equals` with parameters `action=` which restricts the action to any of `create`, `modify`, `rename`, `remove`, `move`, `search`, `read`, etc.)

## Default example roles

UDM provides some default roles, which are using some builtin capabilities:

- `udm:default-roles:domain-users` allows to read everything non-sensible
- `udm:default-roles:domain-administrator` allows to write everything
- `udm:default-roles:organizational-unit-admin` allows to be admin of a certain OU given by its context
- `udm:default-roles:helpdesk-operator` only allowed to set passwords of users underneath of a certain OU given by its context
- `udm:default-roles:computer-join-administrator` allows to join computers into the domain, and set their corresponding password
- `udm:default-roles:self-service-profile` allows to modify the properties of the own user object specified in UCR variable `self-service/udm_attributes`

## Wildcard permissions

Wildcard permissions allow to not be required to specify a whitelist of all allowed properties to have access to. UDM is a dynamically extensible framework, where new properties can be added 1) via additional schema extensions and 2) on the fly via UDM “extended attributes”.

Supporting wildcard permissions adds a security risk. If customers need to copy our default capability definitions for an example role and in some errata update we introduce new security-relevant properties e.g. another service specific password, customers need to adjust their access definitions prior to the software upgrade. Otherwise a vulnerability time window exists, where access is allowed to these attributes, even if the customer references (in a currently impossible way) our default policies.

Alternative concept to wildcard permissions would be something like a “permission bundle”, where we group certain properties, e.g. `default-users-user-properties`, `custom-users-user-properties`, `sensitive-users-user-properties`.

## Known problems with Guardian

The Guardian component currently has several drawbacks, which has to be solved or circumvented, so that UDM can realize a authorization concept.

### General/Conceptual problems

#### Ambiguity of implementation

“There should be one – and preferably only one – obvious way to do it.” Zen of Python

Guardian allows several ways to implement a use case and its documentation doesn’t give clear answers how things are supposed to be solved.

One can implement a:

- `udm:udm:users-user-{action}` permission, where action is e.g. one of `create`, `modify`, `remove`, `rename`.
- `udm:udm:{action}` permission, which must be used in combination with a condition, checking the `objectType == 'users/user'`
- `udm:udm:action` permission, which checks in multiple conditions that `action == 'modify'` and `objectType == 'users/user'`

One can implement a:

- `udm:udm:users-user-write-property-description` permission
- `udm:udm:write-property-description` permission, which must be used in combination with a condition, checking the `objectType == 'users/user'` and `property == 'description'`
- `udm:udm:action` permission, which checks in multiple conditions that `action == 'modify'` and `objectType == 'users/user'` and `property == 'description'`

One can implement a:

- Portal Tile view based on (virtual) roles present in the target
- Portal Tile view based on the app name in the permission string

**Change request:** The Guardian manual should clearly state in which way things should be implemented and tell it's possible advantages and disadvantages.

## Capabilities are bound to roles

When we want to implement customer use cases in a generic reusable fashion, by providing examples how to realize them, we would create explicit permissions (e.g. `udm:udm:users-user-modify-property`). That would serve as a clear API and allows easy re-use by a customer. If we want to implement generic capabilities, which would serve instead as the API, customers need to copy the whole structure and if we change something in our required examples, they need to adopt it equally to their copies. Capabilities are bound to a specific role. That's a problem and doesn't allow re-use but requires hard-copying. To be useable, a capability definition should stand on its own, not yet assigned to any role. Maybe some concept like a capability bundle could enhance this.

**Change request:** The Guardian should remove the role assignment from the capability and introduce a different layer in the Management API to link (multiple) capabilities to (multiple) roles.

## Restricted charset

Guardian restricts the charset of permissions (basically: `[a-z0-9]`). UDM modules, properties and extended attributes allow arbitrary characters. We need to create a mapping of UDM module and UDM property names.

- The mapping is irreversible when we need to strip characters (Increases the complexity very much in handling this).
- The mapping is error prone
- For Administrators this is also intransparent, as they have to remember `pwdChangeNextLogin` and `pwdchangenextlogin`.

1. It's not possible to use `users/user` or `pwdChangeNextLogin`.
2. It would be nice to use the `:` as separator for concepts in permission names e.g. `{app}:{namespace}:$module:$action:$thing`.



3. It would be nice if the whole character set of LDAP DN's is allowed (see later about "Contexts").

**Workaround:** lowercase all values and replace special chars with - and nothing

**Change request:** The Guardian should allow for `app` names, namespaces, permissions and in `contexts` all printable ASCII characters, except for the separator `&`.

### Capability namespace binding restricted to the permission namespace

Guardian has a concept of `app:namespace:thing` for permissions, capabilities, roles, etc. In UDM it would have been nice to use the namespaces for the UDM modules. e.g.: `udm:users/user:...`  would allow things like `udm:users/user:{action}:{property}:{details}`.

But capabilities are bound to be in the same namespace as its permissions. So it is not possible to create a capability which grants permissions for more than one UDM module.

**Workaround:** Create a capability for each namespace (UDM module), so that a domain administrator e.g. needs to get over 100 capabilities assigned.

**Change request:** The Guardian should allow `capabilities` - to reference `permissions` outside of the `namespace` the capability is created in. - to be cloned, so that they can be modified more easily interactively. - to be inherited from another `capability`, and then the sub-capability can add further `conditions` (linked with any relation) which are linked with the super-capability via AND.

The problem realizing this, is that Guardian cannot just search for all capabilities in a certain namespace anymore but must inspect all capabilities, which include permissions of a given namespace.

### No dynamic contexts allowed

While we would benefit from dynamic permissions, because UDM properties and modules can be added dynamically, having such functionality is crucial for `Contexts`. If we want to use the `context` Guardian concept we want to extend permissions so operations are e.g. restricted to targets underneath of a certain OU.

1. A context cannot have the full character set of a LDAP DN (basically also restricted to `[a-z0-9]`). So we cannot add a context `udm:udm:ou-admin & udm:contexts:ou=ou2,dc=example,dc=org`
2. Every context must be registered in guardian. This requires that everytime a OU is created or removed, the context must be added/removed in Guardian. A listener module would have to do this, which adds unnecessary overall complexity to the whole system.

A concept of named context would be good, so that the value is freely chosen but the context name is registered in guardian. One could name a context `udm:contexts:ou` and it's value would be `ou=My school 1,dc=example,dc=org` so that the resulting role string would be `udm:udm:organisational-unit-administrator&udm:contexts:ou=ou=My school 1,dc=example,dc=org`.

It would allow be nice if multiple contexts could be given per role, not just only one. This could be realized by separating them by `&`.

→ Values for contexts should be free-form strings, without having to be registered in Guardian.

**Workaround:** Use the context name, rewrite the roles to strip out parts of the context and gather the data hardcoded in UDM code and provide them via Guardians **extra-arguments**

**Change request:** The Guardian should allow to register contexts and allows assigning free-from string values for them in the role string by separating them via the first = (e.g. `udm:default-roles:organisatzional-unit-administrator&udm:general:ou=ou=My school 1,dc=example,dc=org`).

**Change request:** The Guardian should allow to specify multiple contexts in a role string, separated via & (e.g. `udm:roles:foo-role&context1&context2`).

### No removal in Guardian possible

The guardian management API and UI doesn't allow to remove any created object like `app`, `namespace`, `role`, `context`, `permission`, `condition`. Only a capability can be removed.

**Change request:** The Guardian Management API should implement the endpoints to remove Guardian objects (and the UI should use it).

[univention.com/components/authorization-engine/guardian#262](https://univention.com/components/authorization-engine/guardian#262)

### Permission granting: no negative permissions

Guardian allows to give permissions but has no way to reduce already given permissions by a further capability (additive permission management without subtractive permission management).

This is fundamental for our requirements. UDM is dynamically extensible and is also evolving, so that we sometimes add new properties.

1. Guardian requires for each changeable property a permission to be defined.
2. Guardian doesn't have a wildcard permission granting concept
3. If we introduce a wildcard concept, we cannot use the check-permission endpoint anymore: We have to do the whole rule evaluation in UDM.
4. If we introduce a permission-restriction-afterwards concept we cannot use the check-permission endpoint anymore: We have to do the whole rule evaluation in UDM, see the below realization idea how Guardian could support it.
5. If we don't have a wildcard concept, we have to adjust existing rules on every software upgrade / extended attribute.
6. If we don't have a wildcard concept, we will send very large amount of permissions strings on each rule evaluation check.

Drawbacks of negative permissions: \* If a user contains two roles, e.g. `helpdesk-operator` which grants access to `users/user:write-property-password` and another OU specific role which disallows access via `users/user:none-property-password`, the functionatliy of the first role would be destroyed: In some cases this could mean that you have less permissions then before, which is not something Administrators would expect. This can partly be solved by adding specific conditions to the capabilities which let the permissions only apply to e.g. a certain subtree.

**Realization idea:** Guardian could also provide parameters to check for the absence of permissions.

```
permission_check(  
    general_permission=["users-user:modify"],
```



```

    target_permission=["users-user:write:description"],
    not_target_permissions=["users-user:readonly:description"],
    not_permissions=["users-user:none:description"]
)

```

## No language to describe rules, just HTTP API endpoints with JSON payloads

As far as I know, Univention wants to use industry standards, combine existing products, use industry standard software. Univention wants to remove it's own Univention-inventions.

This is not achieved by implementing custom HTTP APIs with custom data formats or just by using OpenPolicyAgent.

The Guardian HTTP APIs introduce Univention inventions, specific data formats in JSON, which must be learned by customers, partners, etc.

Guardian defines the semantic of a language by introducing concepts like “permissions”, “capabilities”, “conditions”, “roles”, “contexts”, etc. Guardian provides no real syntax to realize these concepts. Instead it offers unfinished JSON based HTTP API endpoints with complex data structure. See also [Guardian API design: extensive data format](#).

Other access control systems make their rules describable via a language, such as LDAP ACLs. Guardian allows to describe rules as capabilities, where each capability is like the following JSON format POSTed to the `guardian-management-api`.

A capability grants permissions to a specific role based on optional conditions:

```

{
  "name": "users-user-creation", # must be in the same namespace as the role
  "display_name": "Allow the role udm:udm:users-user-creator to create UDM users/user ob
  "role": {
    "app_name": "udm",
    "namespace_name": "udm",
    "name": "users-user-creator"
  },
  "relation": "AND", # operator in which conditions are linked
  "conditions": [
    {
      "app_name": "udm",
      "namespace_name": "conditions",
      "name": "action-equals",
      "parameters": [
        {"name": "action", "value": "create"}
      ]
    },
    {
      "app_name": "udm",
      "namespace_name": "conditions",
      "name": "objecttype-equals",
      "parameters": [
        {"name": "objectType", "value": "users/user"}
      ]
    }
  ]
}

```

```

],
"permissions": [
  {
    "app_name": "udm",
    "namespace_name": "udm",
    "name": "create"
  }
]
}

```

This data format is bloated, not changeable, not directly focused on what it offers, not intuitively understandable. Changing the underlying implementation will change everything.

UDM should abstract away these implementation details and provide a easy to understand format, where this HTTP API JSON syntax is created from.

We assume customers don't want to write such error prone JSON blobs. What are configuration formats which are nearly standards, and easy to parse?

URIs are a concept which allow to express this as well. We could also invent a YAML format.

**Example::** One example to describe the default rules for our uses cases is in example2.yaml, which are 100 lines of YAML instead of 24.362 lines of JSON within 143 files.

**Example2::** A easy to understand, human read- and writeable, UDM domain specific language (DSL) in extended BNF grammar inspired by LDAP ACLs, easily parseable by a LALR parser:

```

named-condition "is-self"
  condition="guardian:builtin:target_is_self"

named-condition "in-global-users-container" # unused example
  condition="udm:conditions:target_position_in" # the guardian condition name
  parameters position="cn=users" scope="subtree" # any key value pair which the guardian

# Organizational Unit Administrators
access by role="udm:default-roles:organizational-unit-admin" context="udm:contexts:position"
  description="Organizational Unit Administrators can administrate users and groups in the"

  to objecttype="container/ou" position="{context}" scope="subtree"
    grant actions="search,read"
    grant properties="*" permission="read"

# mail/domain permission in global mail container
to objecttype="mail/domain" position="cn=domain,cn=mail,{ldap_base}" scope="subtree"
  grant actions="search,read"
  grant properties="*" permission="read"

# user permissions in OU
to objecttype="users/user" position="{context}" scope="subtree"
  description="Write user object in own OU" name="users-user-ou-write"
  grant actions="search,read,create,modify,rename,remove,move"
  grant properties="username,lastname,firstname" permission="write"
  grant properties="password,serviceSpecificPassword" permission="writeonly"
  grant properties="guardianRoles" permission="none"

```

```

grant properties="guardianInheritedRoles" permission="none"
grant properties="*" permission="write"

# group permissions in OU
to objecttype="groups/group" position="{context}" scope="subtree"
  grant actions="search,read,create,modify,rename,remove,move"
  grant properties="name" permission="write"
  grant properties="password,serviceSpecificPassword" permission="writeonly"
  grant properties="guardianMemberRoles" permission="none"
  grant properties="guardianMemberRoles" values="udm:default-roles:domain-users,udm:de
  grant properties="*" permission="write"

# Domain Administrators
access by role="udm:default-roles:domain-administrator"
  description="Domain Admins are allowed to do anything in the whole domain"
  to objecttype="*"
    grant actions="*"
    grant properties="*" permission="write"

# Self service use cases
access by role="udm:default-roles:self-service-profile"
  to objecttype="*" actions="modify" properties="jpegPhoto,e-mail,phone,roomnumber,depart

```

**Workaround:** We are currently going with the second approach and transform this into the required Guardian objects.

## Security Impacts

### Availability of UDM

Currently, UDM's only dependencies are the OpenLDAP server and UCR DB availability. Doing authorization via Guardian involves a lot more required components (single points of failure): Keycloak, Guardian Authorization API, Open Policy Agent, PostgreSQL. This opens the way up for:

1. robustness issues
  - if one component is not available, and this can happen often during server maintenance and updates, the central UDM identity management is prevented
  - do we have enough retry mechanisms to deal with this?

We had a support case which took weeks to solve because Keycloak couldn't be reached.

2. security issues
  - Denial of Service has a larger attack surface (attacking just Keycloak makes UDM unusable)
  - Denial of Service of UDM affects the other services. Just throw enough requests against various UDM instances to get the other components Co-DoSed.
  - Overtaking one component via one vulnerability in the stack allows overtaking the full domain
3. scalability issues
  - the above systems are the security foundation of the domain, i.e. they must not run on memberservers or replicas but only on DC Primary and DC backup systems

#### 4. cyclic dependency issues

- e.g. joinscripts
- guardian-management-api → guardian-authorization-api → UDM REST API → guardian-authorization-api

### Information disclosure

To prevent information disclosure, the whole implementation must return the same response structure as LDAP would do it. E.g. LDAP says “No Such Object” if a search with a certain search base is done. The `cn=admin` account, with which UDM then runs, has permissions to read all those objects. The UDM interfaces must now raise the same exception and signature. When it would say “Forbidden” instead or the output differs otherwise, a arbitrary user can obtain any information. By combining search bases, search filters and search scopes a lot of attack vectors are possible in every API endpoint and further down, as e.g. syntax classes expose a lot of different possibilities.

This is very tricky to realize, it must be realized everywhere and it must be understood by every further UDM developer so that things don’t break when evolving UDM.

The integration of Guardian will make UDM vulnerable to side-channel attacks. If one measures the statistical average time to get such a “no object” response, one can also differentiate wheather a object exists or not. In combination with a LDAP filter, this attack can be made very fine granular. Therefor we also have to do guardian requests for objects, which don’t exists at all. A http request will add enough time to the response so that this gets a real attack vector.

For large environments doing a search with a base underneath of an object which returns more objects than the configured sizelimit will raise an LDAP `SIZELIMIT_EXCEEDED` before any filtering can happen, which will reveal that the object exists.

### OPA/Rego doesn’t know LDAP DNs

In UDM we use the C library `_ldap` for LDAP DN comparisions to make correct comparisons, as our customer environments use special characters like `+`, `=`, `(`, etc. Depending on the request and where data origins from we have different DN formats. e.g. `uid = foo \+ bar,cn=users` is equal to `uid=foo \2b bar,cn=user`.

So our checks in OPA need to know these normalization rules when comparing DN. This is not only from a functional point of view important but also from the security perspective: See the above paragraph; it is required to prevent that actors can enumerate valid LDAP DN. To check if an object exists, they could just give a different DN representation and get different permission results just because LDAP supports both but guardian wouldn’t.

### Guardian as Policy Information endpoint doesn’t add security to the whole system architecture automatically

In some meetings there was the view, that as OPA is a industry standard and proven by large companies, just integrating it will make our architecture more secure. OPA with Rego is a language to easily write a permission system without side effects (clear input and output) and a restricted environment. That’s great. But in the end, Guardian is the Policy Information Point and UDM is the Policy Enforcement Point. Therefore the whole permission evaluation is done in the client (UDM), which is more complexity than the whole logic happening in Guardian.

## **Guardian has no way to trace decisions**

A BSI-Grundschrift requirement is that the rule evaluation can be easily traced in logfiles. OPA can log all policy evaluations in detail but the configuration option for `decision_logs` is not integrated in Guardian.

UDM logs all access granting in a structured way.

## **Guardian debugability**

Guardian is the Policy Information Point, UDM is the Policy Enforcement Point so we have two layers where something is decided. With Guardian as an external component involved the debuggability of permission decisions gets hard. We cannot simply trace things in the docker container.

## **Guardian API design: new/old state of targets not required for filtering**

In the Guardian concept the `target` must always be a dictionary with a `new` and a `old` state. While it's not required, to always set a `new` state, this depends on the actual conditions. For some operations like filtering the search results, there is no `old` and `new` state - because the state is equal.

Guardian doesn't clearly document, which builtin conditions operate on which state of the target. The whole `new` and `old` states should just be a client issue, as only they and the conditions give meaning to it.

## **Performance Impacts**

### **Search results must provide full data to Guardian**

We must provide full data, all targets e.g. the search results need to provide all properties and all target roles and inherited roles (depending on the dynamic permissions/conditions). This is not a per-se guardian problem but a general one with the allowed flexibility.

### **Guardian API design: extensive data format**

The Guardian authorization & management API data format is very extensive, e.g. instead of sending : imploded strings, it's always a dictionary `{'app\_name': ..., 'namespace\_name': ..., 'permission\_name': ...}`. This requires way more data transfer, serialization and parsing.

Consider, that the whole JSON serialization and de-serialization in 3 components (UDM, Guardian, OPA) will not be negligible.

TODO: evaluate a different JSON library than the one in the standard library.

### **UDM is synchronous**

While the LDAP library supports asynchronicity, our whole UDM code doesn't use it and runs synchronously. This also applies to the guardian rule evaluation.

### **Rule evaluation stays on the client.**

The logic to enforce the permissions is way more code than what Guardian provides. The CPU intensive step stays on client side.

## check-permissions vs get-permissions endpoints

Guardian basically only offers two endpoints. To realize our requirements we need them in a combined way. We need to check certain general permissions, some target permissions and receive the whole possible permissions (for reasons see above for wildcard-permissions and afterwards-restrictions). This requires us to do always two requests, which are in the backend doing the same logic but just return different results.

It gets even harder, that we cannot let the permissions checked when we have a search result with a mixed set of objects, for example a search for computer objects will return Domaincontroller Slave and Linux Client objects, with different properties. We cannot specify different permissions we need to check per target. Guardian allows only to check all given permissions for all targets. So we need to make multiple requests.

EDIT: This can (at least partly) be solved by not exposing the module name in a permission, but via a additional check in the condition. This, of course, requires all conditions to be linked with the AND relation. With that, we can send mixed targets to the `get-permission` endpoint and receive specific permissions for each of the target, in one request.

## UDM actions do a lot of sub-actions

UDM actions do a lot of sub actions, especially when retrieving objects. We need to check if read permissions for all read references exists so that we don't expose information which is usually not visible to the user.

This requires a lot of checks (via single requests) at different places for one action. UDM is not designed to do a `input representation → just store it in LDAP` operation. It does a lot of sub-operations. UDM Hooks will be even wilder.

Our use case is a secure implementation, not just a "actor can create a user there" and "actor can receive this user". And this must be specifiable by an Administrator. And we need to tell the administrator, what secure is and what not, with good demo examples.

## Management UI Usability problems

The Guardian Management UI is not suitable for the whole UDM domain specific permission/capability assignment. Daniel proposes: > a good UI will display one matrix per UDM module (attribute x permission). Then, the user will not see thousands of permissions/capabilities, but only a few dozen.

So a new UI must be created to be able to work with it. This can by the way, very easily be achieved via a simple UDM module.

## Managment API bugs and issues

### Changing conditions impossible

It's not possible to change a condition, one just get's an Internal Server Error.

→ [univention.com/components/authorization-engine/guardian/#258](https://univention.com/components/authorization-engine/guardian/#258)

### Failed decoding of input JSON data

The management API in my tests crashes permanently randomly. Sometimes the valid JSON input could not be decoded, probably because the full request payload buffer was not read or



reading was too early when the request wasn't yet completely transmitted. The reason could be wrong handling of asynchronicity.

→ [univention/components/authorization-engine/guardian#264](#)

## Unreachable API

Sometimes the Apache gateway says the system is not available: Read timeout: Nothing occurs in the logfiles.

→ [univention/components/authorization-engine/guardian#259](#)

## Performance of Management API

Our joinscript took more than 35 minutes to create all the default permission strings for all UDM object properties. Each call takes at least a second. Re-running the joinscript took 45 minutes, as Guardian only allows to either create OR modify a permission.

There is no PUT endpoint, which allows the creation or modification in one idempotent step.

**Change Request:** All objects in Guardian should support the idempotent PUT endpoint, which creates the object in case it doesn't exist otherwise modify it.

→ [univention/components/authorization-engine/guardian#265](#)

When creating a permission, which already exists, 100 lines of Traceback are logged.

→ [univention/components/authorization-engine/guardian#255](#)

Simply storing all permissions on local JSON files was done in nearly 1 second. A mass-import of the whole structure would help to reduce the performance costs here and would also make sure we always push a idempotent and consistent state for our app "UDM".

## cyclic dependency problem

The guardian-management-api depends on the guardian-authorization-api, which in turn queries the udm-rest-api, which in turn should query the authorization-api to allow access?

## Questions

- How should we solve all the guardian problems in a small time frame, where we have a lot of other issues to solve while we also could just create a simple implementation of all this, which doesn't hinder us in the first step and get us going into a compliant solution?
- How can we implement a solution which allows certain users to bypass the Guardian authorization? It would e.g. help the above cyclic dependency problem and also allows `cn=admin`, which should just have all rights, to
- Do we need to differentiate permission control for UDM REST API, UMC-UDM and UDM-CLI? Can this be achieved via namespaces or via contexts?
- How to handle situations where one is not allowed to read all the groups of a user (e.g. not the Domain Admins or not the OU2-Teacher group) but he wants to modify the user. The client would send back the received groups and just remove the user from all the other groups not allowed to see.

## Conclusion

We don't see the cost-benefit ratio in using the Guardian: \* Why should we use it, when we have to adjust so many things \* Why should we use it, when it creates much overhead like sending a lot of strings see-saw \* If we have to adjust so many things, we have to do in in a generic fashion and have followup work like adjusting manuals, etc. \* why should we adjust it in a generic way if we don't know the exact use cases so it gets usefull for everyone \* are the specific complex things UDM required usefull for every other guardian user or just for UDM? does it give others any value? \* does it make sense to change the Guardian just to satisfy the UDM needs?

## TODOs: describe the following

### Comparison with LDAP ACLs

TODO: describe the following from a problem point perspective

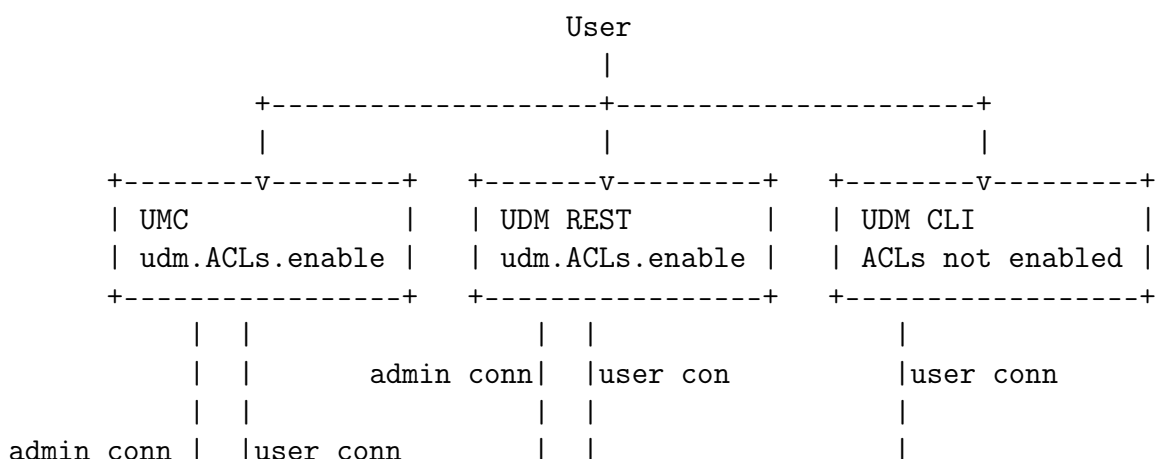
wir müssten bei diesem ganzen ABAC Konzept nochmal das Thema Verzeichnisstruktur bedenken. In LDAP ist es so, dass man um ein Objekt lesen zu können, auf alle übergeordneten Objekte `read` bzw `search`-Rechte auf das `entry` Attribut benötigt und wenn man das Objekt modifizieren will, benötigt man auf das übergeordnete Objekt Lese-Rechte auf das Attribute `children`. Beispiel: um `uid=foo,cn=bar,cn=baz,cn=users,dc=example` lesen zu können brauche ich mindestens: `read` auf `uid=foo,cn=bar,cn=baz,cn=users,dc=example` `attr=entry`, `objectClass`, usw `search` auf `cn=bar,cn=baz,cn=users,dc=example` `attr=entry` (wenn man hier z. B. `add` auf ein Kindobjekt machen will, dann auch `write` auf `children`) `search` auf `cn=baz,cn=users,dc=example` `attr=entry` `search` auf `cn=users,dc=example` `attr=entry` `search` auf `dc=example` `attr=entry`

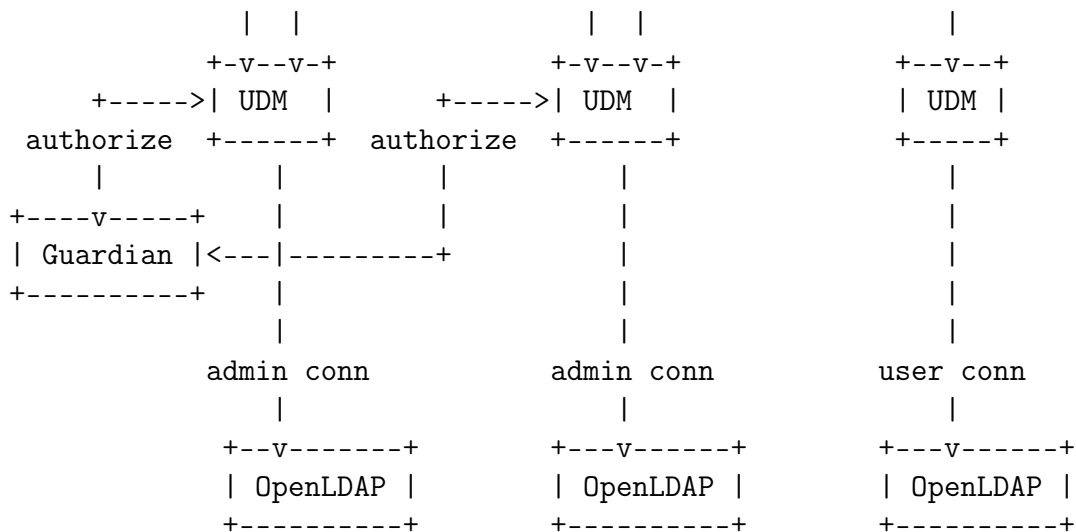
So wie wir es momentan abbilden, ist das völlig außer acht gelassen. Wenn ich `uid=foo,cn=bar,cn=baz,cn=users,dc=example` lesen kann, gibt es keine Regel, die das einschränkt. Das könnte sehr komische Suchergebnisse liefern, wenn man viele `cn`'s gar nicht lesen darf aber eine Suche über den LDAP-Baum macht und dann einfach alle Objekte bekommt, die man lesen darf. Dann gibt es viele Parents nicht.

## Implementation of Authorization in UDM

Historically authorization in UDM was just realised via LDAP ACL's. A new approach, embedding authorization in UDM has been created.

TODO: adjust diagram to actual state





## How to initialize a service to enable the authorization engine?

```

import univention.admin.uldap
from univention.admin.authorization import Authorization

def init_the_service()
    base = ucr.get('ldap/base')
    lo_admin = univention.admin.uldap.getAdminConnection() # cache somewhere
    admin_connection_getter = lambda: lo_admin
    Authorization.enable(admin_connection_getter)

    # get user connection
    lo = univention.admin.uldap.access(binddn='uid=ouladmin,cn=users,dc=ucs,dc=test', bi
    po = position(lo.base)
    lo = Authorization.inject_ldap_connection(lo) # extend user connection to have admin

    users = modules.get('users/user')
    modules.init(lo, po, users)
    user = users.object(None, lo, po, )
    user.create()

```

This injects the user LDAP connection, so that it provides `lo.authz_connection`, which can be used for certain LDAP operations. In general the regular user connection is passed to every other function call like when receiving other UDM objects.

Only when doing direct LDAP operations, the admin connection has to be used, for example the `simpleLDAP.create()` method uses it like:

```

class simpleLDAP:

    def __init__(self):
        self.authz = Authorization()

    def create(self):
        self.authz.is_create_allowed(self)
        self.lo.authz_connection.add(dn, al)

```

This has to be applied for all operations like `get_schema()`, `add()`, `modify()`, `rename()`, `delete()`, `getPolicies()`. Additionally the methods `get()`, `getAttr()`, `search()` and `searchDn()` must not be used but replaced with equivalents, which filter the results for information the user is allowed to read. It's very important that it raises the same exception signature like LDAP would do, if no permissions exists, otherwise with that information leak it would be possible to find out which objects exists, especially if the user has control over the used LDAP filter, it can be used to obtain arbitrary domain data.

Examples of a filtered search:

1. using a LDAP search, searching for all attributes (assuming the results are only `users/user` objects!)

```
user_mod = modules.get('users/user')
user = user_mod.object(None, lo, po)
```

```
results = lo.search_filtered({'module': user.module}, user_filter, user_base)
```

2. using a LDAP search with DNs as result set (assuming the results are only `users/user` objects!)

```
user_mod = modules.get('users/user')
user = user_mod.object(None, lo, po)
```

```
results = lo.search_dn_filtered({'module': user.module}, user_filter, user_base)
```